Backend algorithms and formulae

Updated November 2, 2026. These definitions describe the current implementation, including integer normalization, hashes, budgets and evaluation. They are framework heuristics, not CVSS scores, probabilities or empirical accuracy. See the algorithm reference for control flow.

1. Numeric normalization

Source: `backend/modules/analyzer.py`.

For a value v, default d and inclusive bounds lo/hi:

```
try:
    normalized = max(lo, min(hi, int(v)))
except (TypeError, ValueError):
    normalized = d
```

Driver	Symbol	Range	Default
Exploitability	E	1-5	3
Impact	I	1-5	3
Exposure	X	1-5	3
Confidence	C	0-100	70
Asset criticality	A	0-100	70

Severity is title-normalized to Low, Medium, High or Critical; an unknown severity becomes Low. Numeric bounds apply before scores are computed.

2. Severity and risk

Severity	Numeric score S	Merge rank
Low	25	1
Medium	50	2
High	75	3
Critical	100	4

```
risk = E * I * X
1 <= risk <= 125
```

Risk multiplies the three bounded ordinal drivers. It does not include severity, confidence or asset criticality directly, and is not an exploitation likelihood.

3. Priority

```
priority = round(0.40*S + 0.25*(20*E) + 0.20*A + 0.15*C)
```

Exploitability is scaled from 1-5 to 20-100 before weighting. Priority is presented on a 0-100 scale; the minimum from valid normalized inputs is 15. Python `round` uses ties-to-even, subject to floating-point representation.

Example: High severity, E=4, I=4, X=3, A=70 and C=80:

```
risk = 4 * 4 * 3 = 48
priority = round(30 + 20 + 14 + 12) = 76
```

Impact and exposure affect risk but do not appear directly in priority. Do not substitute one score for the other or label either score CVSS.

4. Finding identity and merge

Source: `backend/modules/analyzer.py`.

```
fields = ("title", "endpoint", "parameter")
identity = "|".join(
    str(finding.get(k, "")).lower().strip() for k in fields
)
fingerprint = sha256(identity.encode()).hexdigest()[:24]
```

The fingerprint keeps 24 hexadecimal characters (96 bits) of SHA-256. It is a deduplication identifier, not an authenticity guarantee. Delimiter-based identity and truncation are implementation choices, not a formal collision-free encoding.

Duplicate merging selects the greatest severity rank and bounded numeric drivers, unions/sorts source tools and appends bounded new evidence. The merged finding is rescored. Distinct host-qualified Nmap endpoints prevent a sweep from collapsing every host's same-numbered port into one finding.

5. Evidence and report digests

Sources: `evidence.py`, `report_versions.py`, `footholds.py`.

Original output hashing uses UTF-8 encoded JSON with the default separators (including spaces) and `ensure_ascii=False`:

```
payload = json.dumps(
    [stdout or "", stderr or ""], ensure_ascii=False
).encode()
evidence_sha256 = sha256(payload).hexdigest()
```

The command is retained in the encrypted original but is not part of this stdout/stderr hash. Public redaction does not change the stored original hash. This digest detects byte changes; it is not a digital signature.

```
report_sha256 = SHA256(exact rendered HTML bytes)
loot_fingerprint = first 32 hex characters of
                   SHA256(secret encoded UTF-8, errors ignored)
```

Report versions retain exact digests even when legacy files become restricted. Encryption keys are required for original recovery; hashes cannot decrypt data.

6. Analysis input budget

Source: `backend/modules/analyzer.py`.

Let R start at 400,000 characters. Iterate executions in order and, for each execution, stdout followed by stderr:

```
take = min(length(stream), 120000, R)
selected = stream[:take]
R = R - take
stop taking content when R reaches zero
```

This is a sequential character budget, not a fair share across executions and not a tokenizer limit. Later streams can receive less space or no space.

Bound	Value
One analysis stream	120,000 characters
All analysis streams	400,000 characters
Findings returned	200
Finding title / endpoint / parameter	500 characters each
Bounded finding text	20,000 characters
Provider response	2 MiB
Provider call timeout	60 seconds

Provider analysis receives redacted input. Independent verification/campaign parsers can inspect protected originals within their own execution bounds.

7. Recommendation digest and correlation rank

Sources: `next_steps.py`, `attack_paths.py`.

Digest/candidate bound	Value
Findings	40
Executions	50
Hosts / footholds / loot	20 each
Individual digest text	300 characters
Serialized digest	12,000 characters
Candidate next steps	6
Driving finding IDs per candidate	5

For a candidate correlation with member findings F:

```
correlation_priority = sum(priority(f) for f in F)
```

Grouping also requires compatible origin/parameter context and meaningful shared findings. The sum orders candidates; it is not a probability, product of exploitability or a proof that all steps can be chained.

8. Scope and engagement windows

Source: `scope_rules.py`.

```
IPv4 network size = 2 ** (32 - prefix_length)
IPv6 network size = 2 ** (128 - prefix_length)
requested_network must be subnet_of(authorized_network)
```

A primary network target is bounded to 256 addresses by default. A /24 IPv4 network has 256 addresses, while a /23 has 512. Checking only the first address does not authorize the entire range.

Exact names require exact matching unless the scope explicitly uses a leading wildcard. Wildcards exclude the apex. URL scopes preserve scheme, effective port and path boundaries. The shared bare host:port helper is not a universal port-isolation check. Whole-host promotion independently rejects URL/path/port- limited permission and any excluded overlap.

For configured start/end times:

```
start <= now < end
```

A missing bound is omitted from the comparison. Invalid or expired policy windows refuse execution rather than silently extending authorization.

9. Execution and live-output bounds

Sources: `executor.py`, `jobs.py`, `worker.py`.

Control	Default
Command execution timeout	360 seconds
Legacy stale-assessment cutoff	360 + 60 = 420 seconds
Worker lease timeout	60 seconds
Execution concurrency	2, clamped to 1-8
Global queued-work limit	100
Captured stdout/stderr	200,000 characters each after bounded byte retention
Private live stream prefix	200,000 characters
Plan steps	50
Autopilot iterations	25
Campaign footholds / loot / hosts	50 / 200 / 512 per assessment

Live output retains the first bounded part of the stream privately. Complete lines pass redaction before publication; an incomplete/overlong line is withheld. The full terminal result is still bounded, not an unlimited forensic recording.

Outcome precedence preserves cancelled, interrupted or timed_out states. A missing return code leaves queued/running work pending. A timeout signal in stderr yields timeout. Otherwise ZAP baseline codes 1/2 mean completed_with_findings, code 0 means completed, and other codes mean failed.

10. Revision claims and atomic publication

Sources: `workflow.py`, `main.py`, `report_versions.py`.

The logical compare-and-swap contract is:

```
UPDATE assessment
SET workflow_revision = expected_revision + 1
WHERE id = assessment_id AND workflow_revision = expected_revision

publish only if exactly one row matched
```

ORM versioning and explicit claims coordinate different write paths. Slow analysis/report/provider work must validate its original revision and relevant attempts before publication. A conflict returns 409; it is not permission to retry a scanner.

Plan versions track reviewed plan edits separately. An unchanged save may advance that version while preserving current analysis/report. Hashes and versions answer different questions: bytes versus workflow freshness.

11. Evaluation definitions

Source: `backend/modules/eval_metrics.py`.

Evaluation identity uses stripped, case-folded title, endpoint and parameter. This differs from the analyzer's lowercased hashed fingerprint; preserve the implementation distinction when reproducing metrics.

For structured ground truth, let O be the set of observed identities, T the set of expected identities and M their intersection:

```
matched = size(O intersect T)
recall = matched / max(1, size(T))
precision = matched / max(1, size(O))
```

Precision is reported only when ground truth explicitly declares itself complete. Otherwise it is null: an unmatched finding is not automatically a false positive when truth is incomplete. A legacy title checklist supports title-match recall, with precision null.

Among matched expected entries with a boolean verification label:

```
verification_accuracy = correct_verification_labels / labeled_matches
```

When there are no labeled matches, verification accuracy is null. The harness reports measured phase times and run summaries; repeated runs and ablation should use the same reviewed targets and truth. No speedup or accuracy number is supplied by these formulas alone.

12. Validation record and regeneration

The testing guide records the November 2 full backend result (412 tests), later focused checks and 24 frontend tests, with their limits. These checks used isolated storage and synthetic evidence.

This Markdown is the source for the matching PDF. From the repository root:

```
python make_backend_algorithms_formulae_pdf.py
```

Use deployment and upgrade notes for key sharing, migrations and live validation before operating a deployment.